Software Seguro

```
root@software-seguro:~# ./start_course.sh
```

Clase 4: Metodología de Reporte Profesional y CVSS

Curso Profesional de Ciberseguridad Web y Ethical Hacking

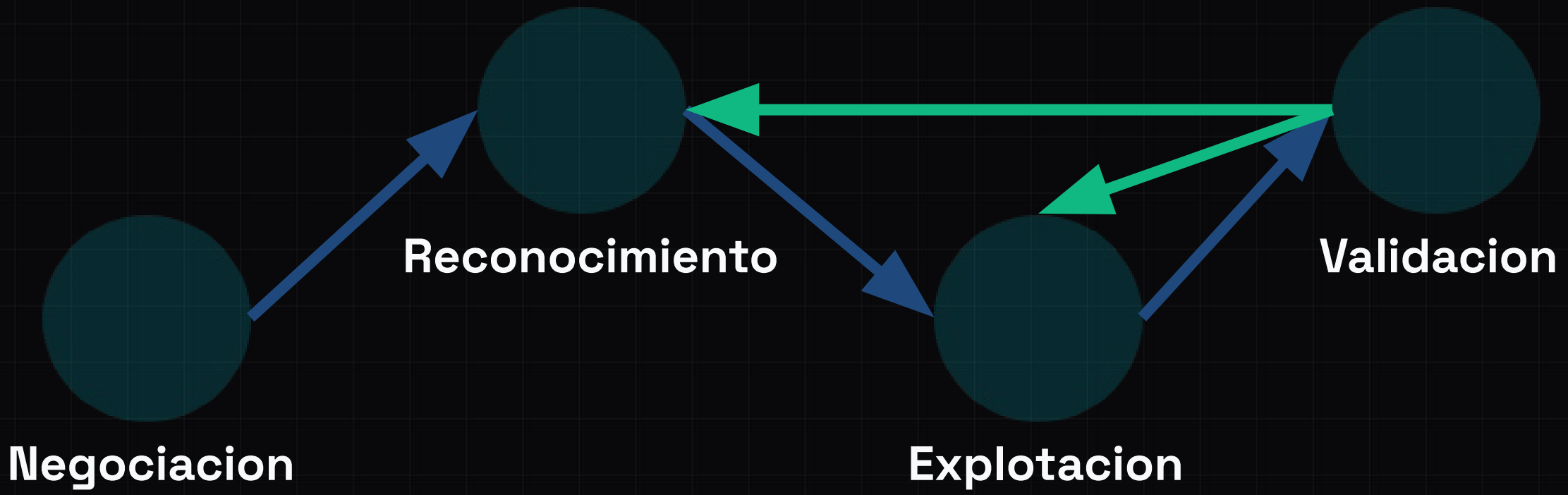
Repaso labs Clase 3

Apagar la IA, El mejor secreto, Votación y Votación nueva versión.

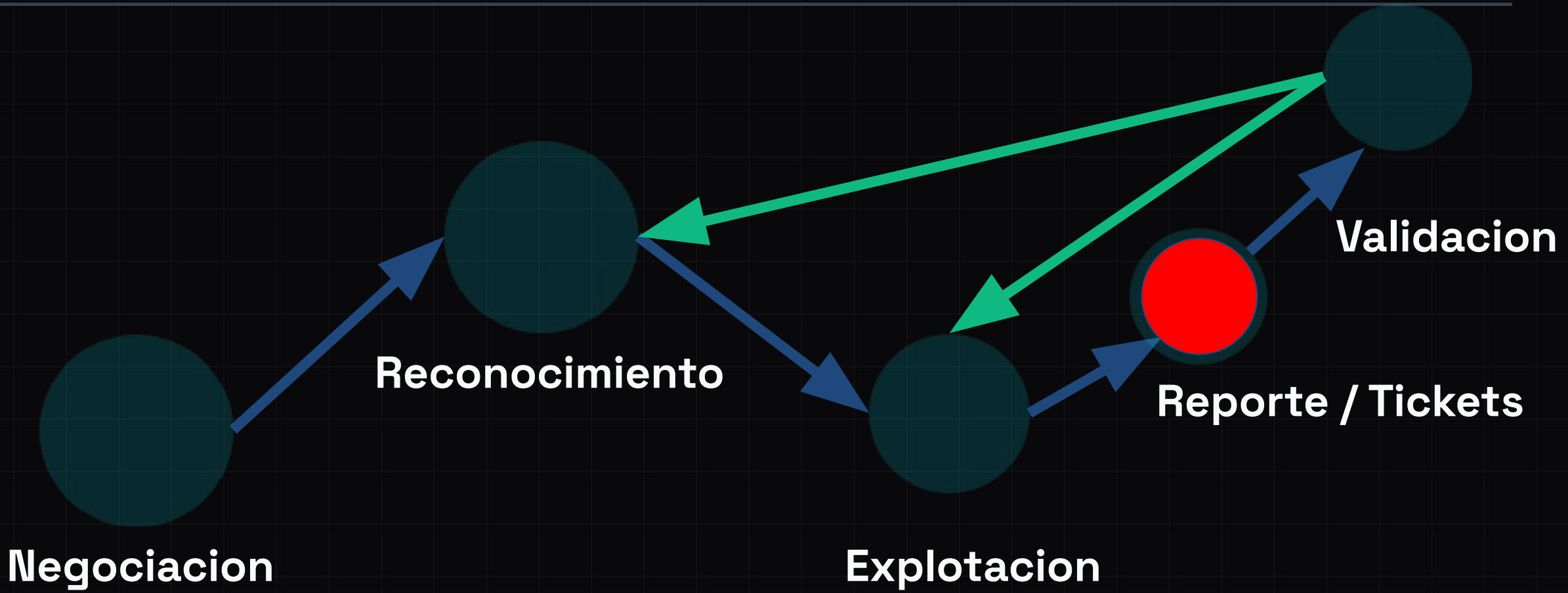
Objetivos de la Sesión

Traducir el conocimiento técnico en documentación corporativa de alta calidad que permita a los desarrolladores solucionar problemas y a los directivos evaluar riesgos.

Etapas del pentesting web



Etapas del pentesting web



Para qué realizamos un reporte

El reporte como producto final: Un pentest o evaluación técnica vale tanto como el reporte que lo describe; si el cliente o el equipo interno no entiende el impacto, el riesgo persiste.

> **Resumen Ejecutivo (C-Level / Directivos):** Enfoque 100% de negocio. Se habla en términos de riesgo operacional, pérdida monetaria, fuga de propiedad intelectual, continuidad del servicio y cumplimiento regulatorio (GDPR, PCI-DSS, leyes locales). Cero jerga cruda; uso de gráficos de severidad y planes de acción a alto nivel.

> **Cuerpo Técnico (Desarrollo, DevOps, Sysadmins):** Rutas exactas, endpoints, encabezados HTTP, payloads específicos, precondiciones de red/autenticación y pasos de remediación directamente aplicables en código o infraestructura.

Tríada CID: Pilares Fundacionales

Toda vulnerabilidad de software impacta en la Confidencialidad, Integridad o Disponibilidad del sistema.

$$\text{Riesgo}_{CID} = \text{Severidad} \times (\text{Falla_C} + \text{Falla_I} + \text{Falla_D})$$

Confidencialidad en el Código

Definición: Asegurar que los datos y secretos de la aplicación sean legibles únicamente por los destinatarios autorizados.

- **Control de Acceso (BOLA / IDOR):** Proteger las APIs verificando que el usuario autenticado realmente tiene autorización explícita para consultar el recurso solicitado.
- **Cifrado en Tránsito y Reposo:** Forzar HTTPS/TLS 1.3 y cifrar campos sensibles de la base de datos (tarjetas, contraseñas, PII) con algoritmos estándar como AES-256.
- **Fuga de Información en Logs:** Evitar la escritura accidental de tokens, cookies de sesión o secretos del sistema en los logs de depuración (Stack Traces).



Integridad del Software

Definición: Prevenir que el código, los flujos lógicos o los datos del sistema sufran manipulaciones, alteraciones o inyecciones maliciosas.

- **Prevención de Inyecciones:** Utilizar consultas preparadas (ORMs parametrizados) y sanitizar entradas para bloquear ataques SQL, Command o LDAP Injection que alteren la BD.
- **Firma Digital de Artefactos:** Asegurar que las dependencias externas (npm, NuGet, pip) no estén comprometidas mediante validación de hashes criptográficos (SCA).
- **Hashing Seguro:** Implementar funciones hash criptográficas (como SHA-256) y códigos de autenticación (HMAC) para verificar que los registros de auditoría (logs), configuraciones del sistema y datos históricos no hayan sido alterados o manipulados.



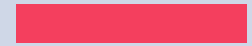
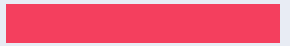
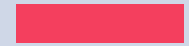
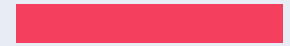
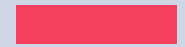
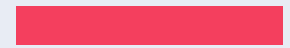
Disponibilidad y Resiliencia

Definición: Garantizar que el sistema, las APIs y los recursos estén accesibles y funcionales de forma ininterrumpida para los usuarios.

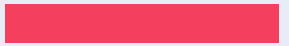
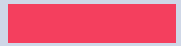
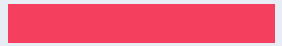
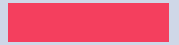
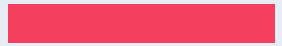
- **Tolerancia al Abuso (Rate Limiting):** Proteger endpoints críticos (como logins) contra denegación de servicios (DoS) controlando el número máximo de peticiones por IP/usuario.
- **Gestión Eficiente de Recursos:** Evitar fugas de memoria (Memory Leaks) cerrando siempre conexiones de bases de datos y manejando timeouts para conexiones externas.
- **Patrón Circuit Breaker:** Evitar fallos en cascada en microservicios aislando temporalmente llamadas a APIs externas lentas o caídas para que la aplicación principal siga activa.



Escenarios CID Interactivos

Incidente Registrado	Impacto en el Software / Sistema	Pilar No Cumplido
Ataque de Ransomware	Infección que cifra la base de datos principal, impidiendo cualquier consulta de negocio.	
Fuga de Datos Internos	Exfiltración accidental de base de datos que contiene salarios, contraseñas y datos PII.	
Inyección de Balance Financiero	Alteración de montos bancarios mediante alteración directa de los payloads JSON en una API externa.	
Login / reset password	Funcionalidad que devuelve mensaje como usuario no encontrado o contraseña incorrecta	
Endpoin de actualizacion mediante id sin control de acceso	El usuario puede modificar los datos de su perfil la consulta se ve como esto PUT /api/profile → {“id”: 1, “name”: “German”}	
Falta de validación en la subida de archivos	Los documentos subidos se procesan en la ram del servidor, no hay validación de entrada o esta solo en el frontend	

Escenarios CID Interactivos

Incidente Registrado	Impacto en el Software / Sistema	Pilar No Cumplido
Ataque de Ransomware	Infección que cifra la base de datos principal, impidiendo cualquier consulta de negocio.	Disponibilidad
Fuga de Datos Internos	Exfiltración accidental de base de datos que contiene salarios, contraseñas y datos PII.	
Inyección de Balance Financiero	Alteración de montos bancarios mediante alteración directa de los payloads JSON en una API externa.	
Login / reset password	Funcionalidad que devuelve mensaje como usuario no encontrado o contraseña incorrecta	
Endpoin de actualizacion mediante id sin control de acceso	El usuario puede modificar los datos de su perfil la consulta se ve como esto PUT /api/profile → {“id”: 1, “name”: “German”}	
Falta de validación en la subida de archivos	Los documentos subidos se procesan en la ram del servidor, no hay validación de entrada o esta solo en el frontend	

Escenarios CID Interactivos

Incidente Registrado	Impacto en el Software / Sistema	Pilar No Cumplido
Ataque de Ransomware	Infección que cifra la base de datos principal, impidiendo cualquier consulta de negocio.	Disponibilidad
Fuga de Datos Internos	Exfiltración accidental de base de datos que contiene salarios, contraseñas y datos PII.	Confidencialidad
Inyección de Balance Financiero	Alteración de montos bancarios mediante alteración directa de los payloads JSON en una API externa.	
Login / reset password	Funcionalidad que devuelve mensaje como usuario no encontrado o contraseña incorrecta	
Endpoin de actualizacion mediante id sin control de acceso	El usuario puede modificar los datos de su perfil la consulta se ve como esto PUT /api/profile → {“id”: 1, “name”: “German”}	
Falta de validación en la subida de archivos	Los documentos subidos se procesan en la ram del servidor, no hay validación de entrada o esta solo en el frontend	

Escenarios CID Interactivos

Incidente Registrado	Impacto en el Software / Sistema	Pilar No Cumplido
Ataque de Ransomware	Infección que cifra la base de datos principal, impidiendo cualquier consulta de negocio.	Disponibilidad
Fuga de Datos Internos	Exfiltración accidental de base de datos que contiene salarios, contraseñas y datos PII.	Confidencialidad
Inyección de Balance Financiero	Alteración de montos bancarios mediante alteración directa de los payloads JSON en una API externa.	Integridad
Login / reset password	Funcionalidad que devuelve mensaje como usuario no encontrado o contraseña incorrecta	Confidencialidad
Endpoin de actualizacion mediante id sin control de acceso	El usuario puede modificar los datos de su perfil la consulta se ve como esto PUT /api/profile → {“id”: 1, “name”: “German”}	
Falta de validación en la subida de archivos	Los documentos subidos se procesan en la ram del servidor, no hay validación de entrada o esta solo en el frontend	

Escenarios CID Interactivos

Incidente Registrado	Impacto en el Software / Sistema	Pilar No Cumplido
Ataque de Ransomware	Infección que cifra la base de datos principal, impidiendo cualquier consulta de negocio.	**Disponibilidad**
Fuga de Datos Internos	Exfiltración accidental de base de datos que contiene salarios, contraseñas y datos PII.	**Confidencialidad**
Inyección de Balance Financiero	Alteración de montos bancarios mediante alteración directa de los payloads JSON en una API externa.	**Integridad**
Login / reset password	Funcionalidad que devuelve mensaje como usuario no encontrado o contraseña incorrecta	**Confidencialidad**
Endpoin de actualizacion mediante id sin control de acceso	El usuario puede modificar los datos de su perfil la consulta se ve como esto PUT /api/profile → {“id”: 1, “name”: “German”}	**Integridad**
Falta de validación en la subida de archivos	Los documentos subidos se procesan en la ram del servidor, no hay validación de entrada o esta solo en el frontend	

Escenarios CID Interactivos

Incidente Registrado	Impacto en el Software / Sistema	Pilar No Cumplido
Ataque de Ransomware	Infección que cifra la base de datos principal, impidiendo cualquier consulta de negocio.	**Disponibilidad**
Fuga de Datos Internos	Exfiltración accidental de base de datos que contiene salarios, contraseñas y datos PII.	**Confidencialidad**
Inyección de Balance Financiero	Alteración de montos bancarios mediante alteración directa de los payloads JSON en una API externa.	**Integridad**
Login / reset password	Funcionalidad que devuelve mensaje como usuario no encontrado o contraseña incorrecta.	**Confidencialidad**
Endpoin de actualizacion mediante id sin control de acceso	El usuario puede modificar los datos de su perfil la consulta se ve como esto PUT /api/profile → {“id”: 1, “name”: “German”}	**Integridad**
Falta de validación en la subida de archivos	Los documentos subidos se procesan en la ram del servidor, no hay validación de entrada o esta solo en el frontend.	**Disponibilidad**

Ticket / issue

- Numero ID
- Nombre representativo
- Categoria
- Score (Por ejemplo Vector CVSS 3.0)
- URL afectadas
- Endpoints afectado
- Descripción
- Paso a paso - ¿Cómo reproducirlo?
- Mitigación / Recomendación
- Evidencias



TICKET DE SEGURIDAD

Vulnerabilidad: Exposición de información sensible en endpoint de consulta

ID: SEC-2025-047

Fecha: 2025-06-16

Estado: Abierto

Nombre representativo	Exposición de información sensible en endpoint de consulta
Categoría	Information Disclosure (Exposición de Información)
Score (CVSS 3.0)	**7.5 (High)** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
URL afectadas	https://api.ejemplo.com/v1/usuarios/ https://api.ejemplo.com/v1/perfil
Endpoints afectado	GET /v1/usuarios/{id} GET /v1/perfil
Descripción	Se identificó que el endpoint de consulta de usuarios expone información sensible sin requerir autenticación ni autorización adecuada. Cualquier usuario autenticado o incluso no autenticado (según la configuración del entorno) puede acceder a datos como correos electrónicos, números de teléfono, roles y hashes de contraseña.
Paso a paso – ¿Cómo reproducirlo?	1. Obtener un token válido (o usar un usuario sin autenticación si el endpoint no requiere auth). 2. Realizar una petición GET al endpoint /v1/usuarios/{id} con un ID existente. 3. Observar la respuesta que incluye datos sensibles del usuario. 4. Repetir con otros IDs para confirmar la exposición masiva.
Mitigación / Recomendación	• Implementar control de autenticación y autorización en el endpoint. • Limitar los datos expuestos (principio de mínimo privilegio). • Validar el rol del usuario antes de permitir el acceso. • Considerar el uso de paginación y filtros para evitar la enumeración masiva. • Revisar y endurecer la configuración de CORS y headers de seguridad.

Evidencias	**1. Petición realizada**
	`GET /v1/usuarios/12 HTTP/1.1`
	`Host: api.ejemplo.com`
	`Authorization: Bearer eyJhbGciOiJIUzI1NiIs...`
	2. Respuesta del servidor
	`{ "id": 12, "nombre": "Juan Pérez", "email": "juan@ejemplo.com", "telefono": "+5493511234567", "rol": "admin", "password_hash": "$2y$10$..." }`
	3. Vista en navegador (formato JSON)
	https://api.ejemplo.com/v1/usuarios/12
	`{ "id": 12, "nombre": "Juan Pérez", "email": "juan@ejemplo.com", "telefono": "+5493511234567", "rol": "admin", "password_hash": "$2y$10$..." }`

Common Vulnerability Scoring System

El CVSS (Common Vulnerability Scoring System) es un estándar abierto diseñado para medir la gravedad de una vulnerabilidad de seguridad informática de forma numérica y consistente, de modo que pueda ser comprendida y comparada fácilmente por técnicos, gestores de riesgos y organizaciones.



Common Vulnerabilities and Exposures

El estándar de OWASP para verificar la seguridad de aplicaciones web. Checklist interactivo de requisitos para auditar tu desarrollo nivel por nivel.

V1 - Codificación y sanitización
V2 - Validación y lógica de negocio
V3 - Seguridad del frontend web
V4 - APIs y servicios web
V5 - Manejo de archivos
V6 - Autenticación
V7 - Gestión de sesiones
V8 - Autorización
V9 - Tokens autocontenidos
V10 - OAuth y OIDC
V11 - Criptografía
V12 - Comunicación segura
V13 - Configuración
V14 - Protección de datos
V15 - Codificación y arquitectura segura
V16 - Logging de seguridad y manejo de errores
V17 - WebRTC

Software Seguro

Exploremos ASVS Tracker

Asignación para el Hogar

Resolver y enviar los objetivos del Módulo II: Reporte y Brechas: Metodología de Reporte Profesional y CVS

Ingresar a la plataforma de Software Seguro, en las opciones les aparecera el curso “Curso Profesional de Ciberseguridad Web y Ethical Hacking”, dentro del curso tienen los distintos módulos con sus objetivos que deberán enviar antes de la próxima sesión

¿Preguntas?

Fin de la Sesión 3.

https://softwareseguro.com.ar